

AI 기반 협업 워크스페이스

IP Risk Agent

IP Risk Agent — Secure Human-in-the-Loop IP Risk Management System

GitHub·Google Drive·Local Workspace를 지속적으로 모니터링하여
개발 과정에서 발생하는 특허·라이선스 리스크를 근거 기반으로 조기에 탐지합니다.

팀명	5조
팀원	윤결(팀장) 이현 이은우

INDEX

01 프로젝트 개요

02 프로젝트 팀 구성 및 역할

03 프로젝트 수행 절차 및 방법

04 프로젝트 수행 경과

05 자체 평가 의견

일일이 매번 라이선스 및 특허 위반을 검색해야 합니다

대상 사용자

전담 법무·특허 인력이 부족한
스타트업·소규모 개발팀

- 코드와 문서, 외부 라이브러리 목록이 GitHub·Drive·내 PC에 흩어져 있음
- 기존 검사는 직접 스스로 검색하여 찾아야 했음
- 법무팀이 존재하지 않는 소규모 개발팀에게는 부담

기존의 방식

세 곳을 각각 열어 확인



기존 방식으로 인해 발생하는 문제

어디까지 봤는지 모름

라이선스·특허를 직접 검색



매 검색마다 번거로움 발생

찾은 결과를 스스로 해석

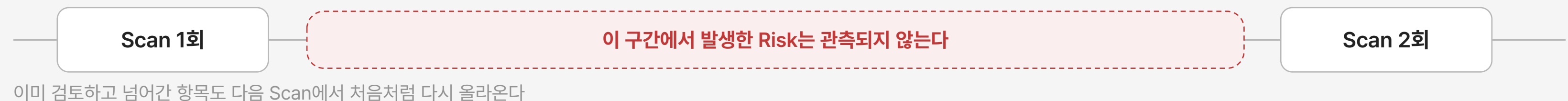


소규모 개발팀에게는 부담

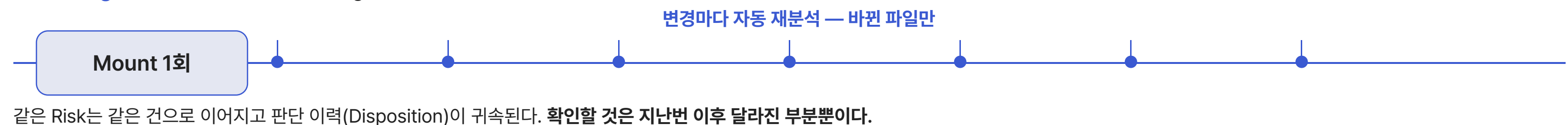
따라서 소규모 개발팀에게 쉽게 IP Risk를 탐색하고 위반 사항을 파악할 수 있는 도구를 제공하기 위해 개발했습니다.

Scan을 반복하는 대신, Risk 하나하나를 상태로 관리합니다

기존 도구 One-shot Scan · 점검은 그때그때의 행위다



IP Risk Agent Continuous Tracking · Risk에 상태와 이력이 붙는다



변경점

미관측 구간

Scan과 Scan 사이에 발생

→ 없음

검토 범위

매번 전체 재검토

→ 변경 파일만

판단 이력

남 았아 매번 재판단

→ Risk에 귀속·보존

Scan 결과를 보관하는 것이 아니라, Risk의 상태와 판단 이력을 관리합니다.

변경을 지속적으로 탐지하고, 근거로 알림을, 판단은 사람이 하게 했습니다

01

지속적인 모니터링

Continuous Monitoring

- Drive 변경 알림 받기
- GitHub 커밋 알림 받기
- 내 PC 파일 감시
- 변경된 파일만 재분석

02

보안 구조

Security by Architecture

- 사용자가 고른 범위만 접근
- 제외 목록 적용
- 파일 종류·크기·비밀정보 검사
- 원본을 저장하지 않음

03

근거 기반 분석

Evidence-grounded

- 특허 DB(KIPRIS)에서 찾은 근거
- 표준 목록(SPDX)으로 라이선스 식별
- 참조 문서에서 의무 조항 검색
- 인용문이 원문에 실제 있는지 확인

04

최종 판단은 사람이

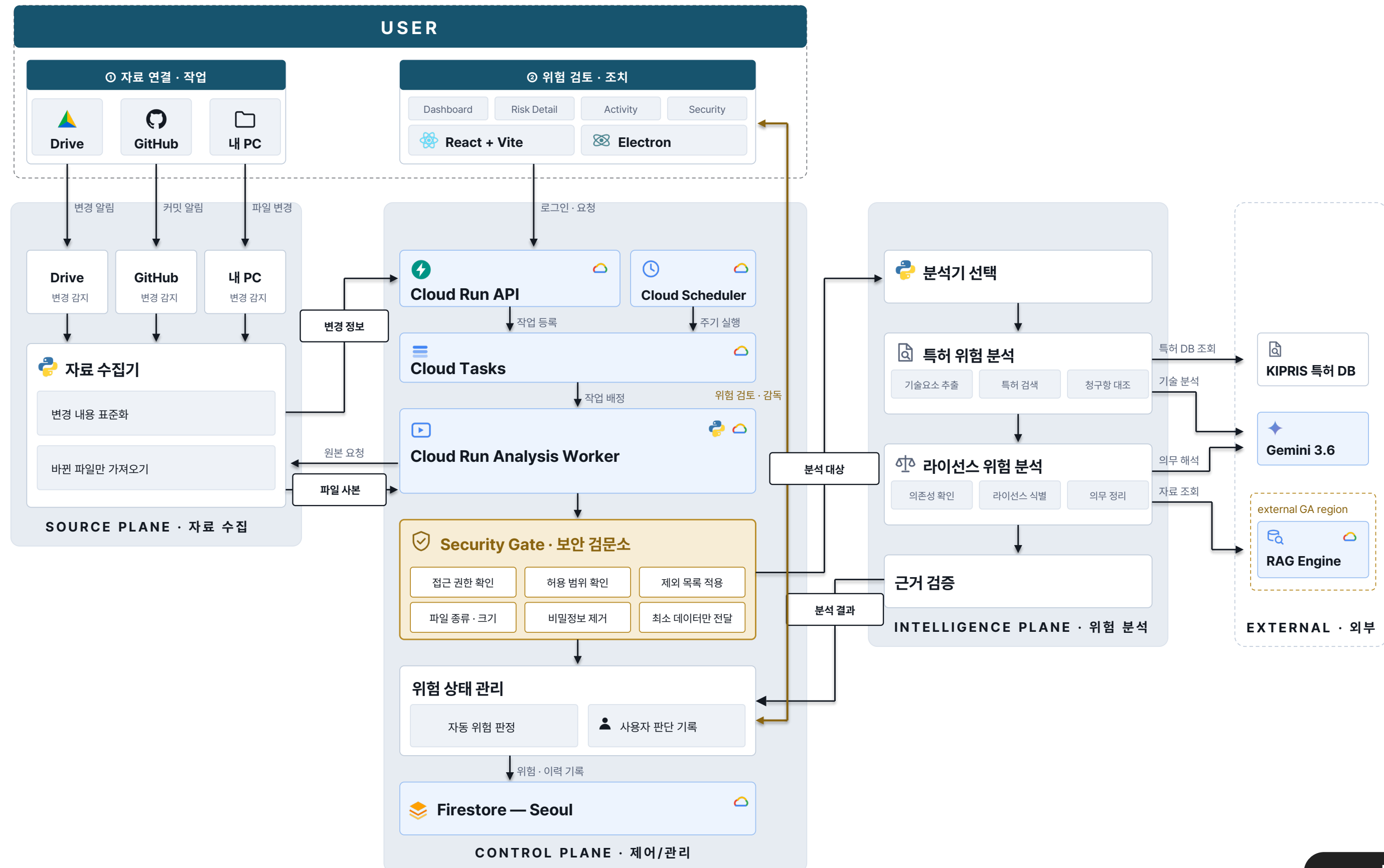
Human-in-the-Loop

- AI는 위험 후보와 근거만 제안
- 위험 상태는 제어 계층이 관리
- 지켜보기·감수하기·제외를 사용자가 선택
- 판단 사유와 이력을 남김

기술 스택

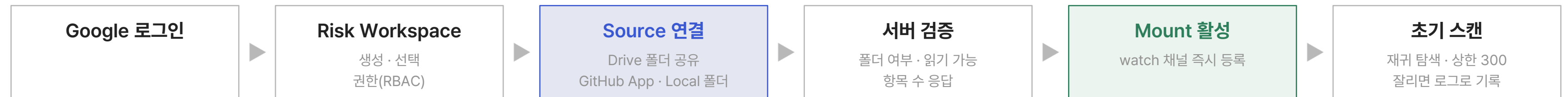
React · Electron · FastAPI · Cloud Run · Cloud Tasks · Firestore · Gemini · KIPRIS · SPDX · RAG

Source · Control · Intelligence, 세 Plane으로 나눴습니다



Source 연결 · 감지와 분석 · HITL 검토, 세 구간이 반복됩니다

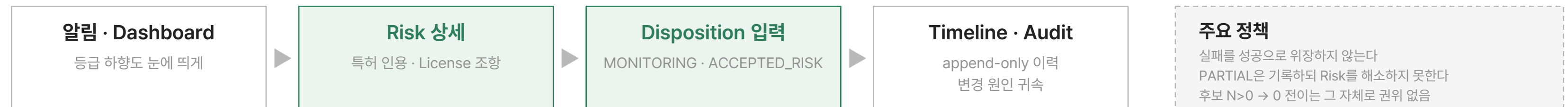
A. 연결과 추적 관리



B. 감지와 분석



C. 검토와 판단 HITL · 최종 판단은 사람이 함



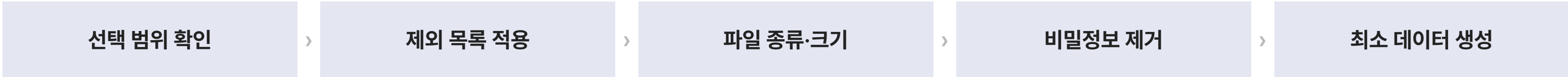
변경 하나가 '근거가 남는 위험 판단'이 되기까지



원본 전체가 아니라 분석에 필요한 최소 범위만 전달합니다

연결 대상	연결 범위	변경 감지	접근 방식
Google Drive	공유받은 폴더	변경 목록 조회	서비스 계정에 보기 권한으로 공유
GitHub	저장소 · 브랜치	커밋 알림	GitHub 앱 설치
내 PC	사용자가 고른 폴더	파일 감시	기기 인증 정보

보안 검문소가 하는 일



직접 확인한 결과

기존 방식(파일 하나씩 권한 부여)으로 폴더 읽지 않도록 설정	5개 중 0개
서비스 계정에 폴더를 공유하고 읽도록 설정	5개 중 5개
파일 추가 · 폴더 밖으로 이동 · 되돌리기 감지	3개 중 3개
사용자 접속 토큰 보관	없음

문서의 가정이 아닌,
실제 Drive 접근 실험 결과가
구조 변경을 결정했습니다.

역할마다 할 수 있는 일을 화면 단위로 고정했습니다

조작 = 실행 권한 · 조회 = 열람만 · — = 불가 역할은 Members & roles 화면에서 부여합니다

화면 · 기능	Viewer	Risk Reviewer	Source Manager	Owner
Overview · Files · Review · Risk 상세 · 타임라인 조회	조회	조회	조회	조회
Reviewer decision — 처분 입력 모달	—	조작	조작	조작
Add source · 마운트 Disable · 다시 검사 · 추적 해제	—	—	조작	조작
Members 초대 · 역할 변경 · 제거	—	—	—	조작
Security & data — .ipriskignore · Workspace 삭제	—	—	—	조작
Activity & audit 조회	조회	조회	조회	조회
safe audit JSON 내보내기	—	—	—	조작
Notifications — 개인 인박스	본인만	본인만	본인만	본인만

앱 권한은 원문 접근 권한을 부여하지 않습니다 — provider 권한(폴더 공유 · App 설치 · 기기 등록)은 매 요청마다 따로 검사합니다.

AI의 답이 아니라 사람이 검토할 수 있는 근거를 만들었습니다

특허 위험 분석



라이선스 위험 분석



AI Agent가 맡은 부분

1단계

판정은 코드에게 (파서·정책 표)

2단계

인용과 근거가 실제 있는지 코드가 검증

3단계

검증된 근거가 있을 때만 Gemini가 설명

최종

위험 상태와 처분은 사람이 판단

세 Plane(계층)을 하나씩 단독 소유하고, 통합은 한 사람이 맡았습니다

Plane 경계를 그대로 담당으로 나눴습니다. 맡은 영역이 곧 코드 소유권입니다.

윤결

Risk Intelligence Plane

위험 분석 계층 · risk-intelligence-rag

- Risk Intelligence Plane 개발
- RAG 파이프라인 구축
- License · Patent 규칙 엔진 구축
- 발표 및 포트폴리오

이현

Control Plane

제어 · 관리 계층 · platform-control

- 초기 명세 · Shared Contract 확정
- Control Plane 개발
- 통합 및 배포
- E2E 테스트

이은우

Source Integration Plane

자료 수집 계층 · source-integration-desktop

- Source Integration Plane 개발
- Source별 Connector 구축
- HITL 검토 화면 구축
- 통합 보고서 문서화

3 branch 병합 — backend 충돌 0건

디렉터리 소유를 사전에 분리하고 Plane 간 통신을 **Shared Contract(고정 데이터 규격)로만** 제한한 결과입니다.

총 다섯 단계로 진행해 구현했습니다

1

문제 정의·구조 설계

- 사용자 문제 정의
- 3계층 구조
- 주고받을 데이터 형식 고정

2

계층별 동시 개발

- 제어 · 관리
- 자료 수집 · 데스크톱
- 위험 분석 · 참조 문서

3

통합·배포

- 접속 서버와 분석 서버 분리
- 작업 대기열과 서버 간 인증
- 저장소 · 정기 점검

4

실제 환경 실측

- Drive 폴더 접근 실험
- 잘못 붙은 근거 측정
- 의존성 누락 발견

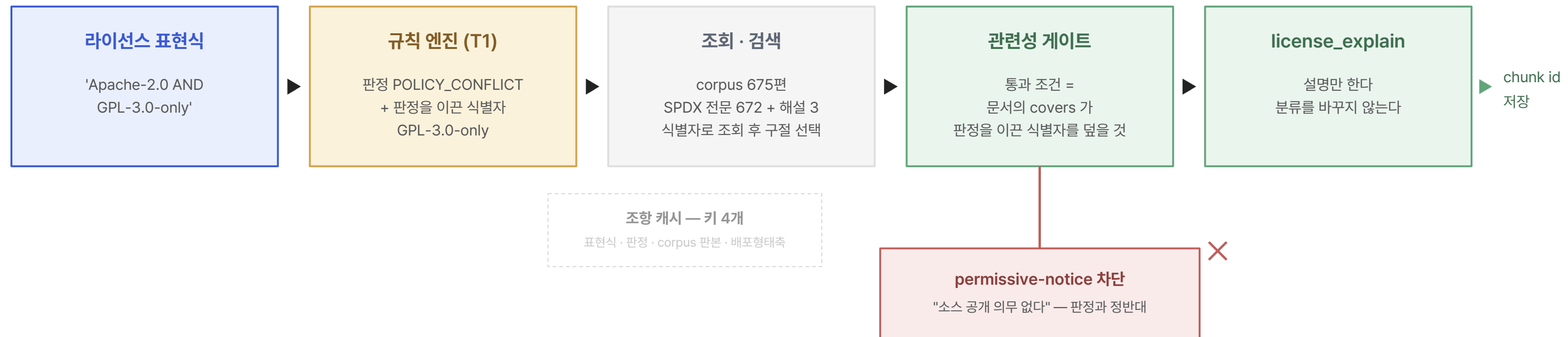
5

결함 수정·최종 검증

- 근거 신뢰 경계 개선
- Drive 접근 방식 재설계
- 전체 재검사 후 재배포

RAG는 판정을 만들지 않고, 내려진 판정에 근거를 겁니다

관련성 게이트 — 판정을 이끈 식별자를 덮는 문서만 근거로 통과시킵니다



판정은 게이트 앞에서 이미 끝나 있다 — RAG 는 근거만 댄다

오부착률

46.4%

→

0

측정값이 아니라 정의입니다

게이트를 통과했다는 것과 근거가 잘못 붙었다는 것은 동시에 참일 수 없습니다

RAG의 활용 부분이 미흡한 점을 수정하여, 더 환각현상을 줄이고자 했습니다

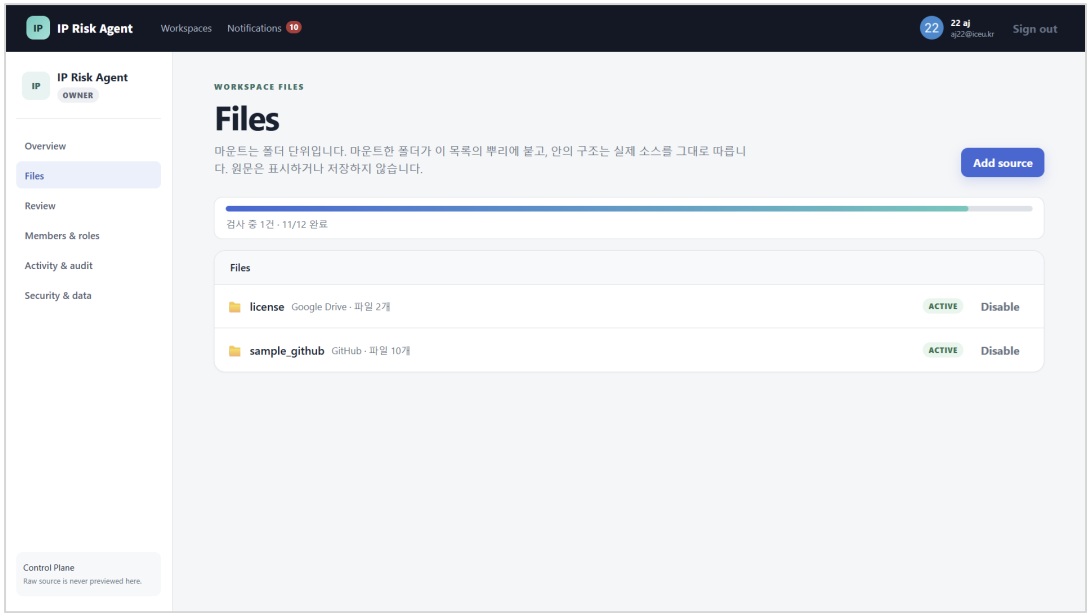
지표	수정 전	수정 뒤
잘못 붙은 근거	46.4%	0%
아는 라이선스 이름	42종	727종
RAG 참조 문서	3편	675편
RAG 참조 문서활용 범위	18.2%	100%
의존성 20건 중 읽어낸 수	3건	20건

무엇을 고쳤는가

- 1 의존성 파일을 조각내지 않고 통째로 분석
- 2 읽기 실패와 "작성 내용 없음"을 구분
- 3 전부 읽음 / 일부만 읽음 / 못 읽음을 구분
- 4 판정을 만든 라이선스가 무엇인지 식별
- 5 그 라이선스를 다루는 문서만 근거로 허용

일부만 읽은 분석은 새 위험을 추가할 수는 있어도, 기존 위험을 "해소됐다"고 닫을 권한은 갖지 못하게 했습니다.

코드·제품 화면·배포 결과로 구현 범위를 검증했습니다



연결 관리 Sources

Drive · GitHub · 내 PC 연결 화면

검증 결과

서버 테스트

1,156건 통과

접수 서버 배포본

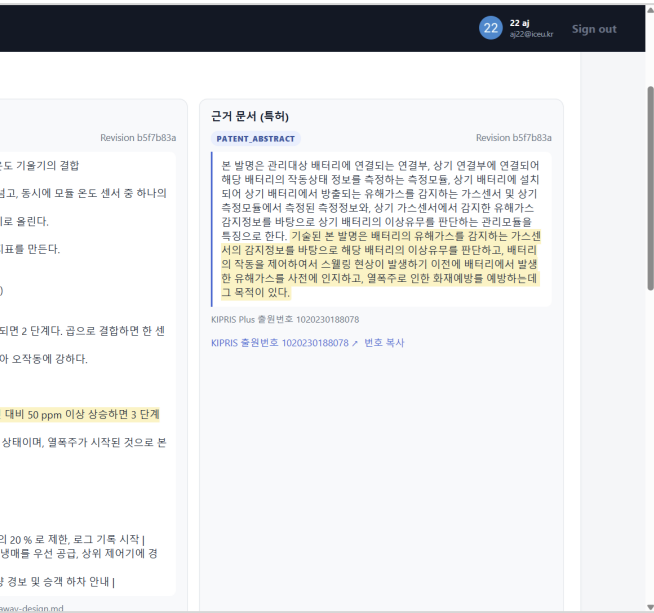
00050-47v

웹 화면 테스트

55건 통과

분석 서버 배포본

00051-ctr



위험 상세 Risk Detail

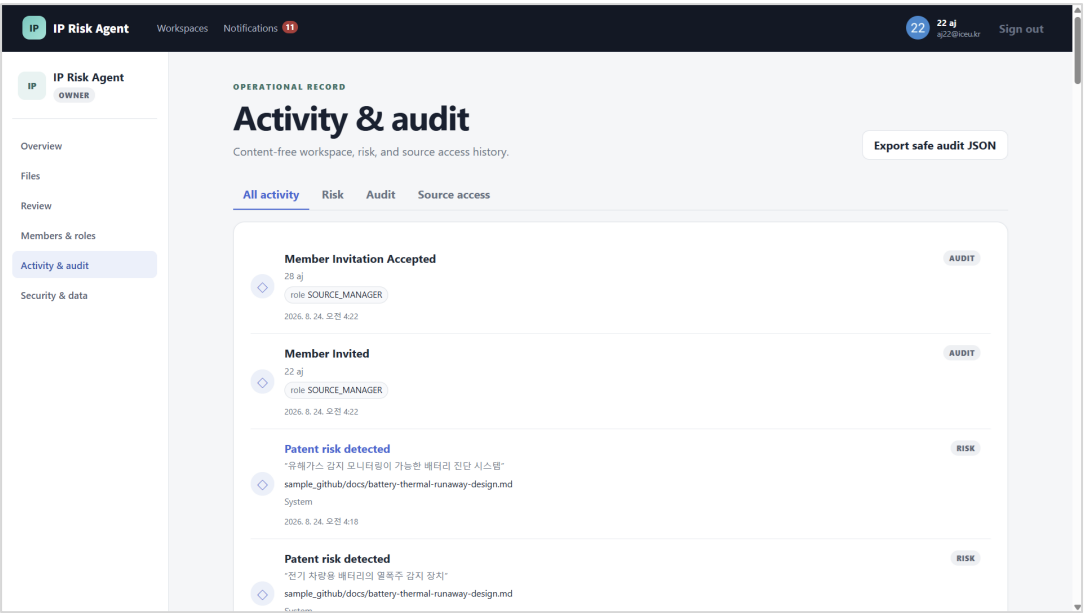
위험 등급, 특허·라이선스 근거, 인용문

데스크톱 테스트

83건 통과

두 서버 실행 이미지

동일



활동 기록 Activity

자동 판정과 사용자 판단 이력

APPENDIX · UI SPECIFICATION

제품 화면 16장의 상세 명세를 부록에 수록했습니다. 이후 페이지는 시연 영상을 대체합니다.

PAGE 17 ~ 34

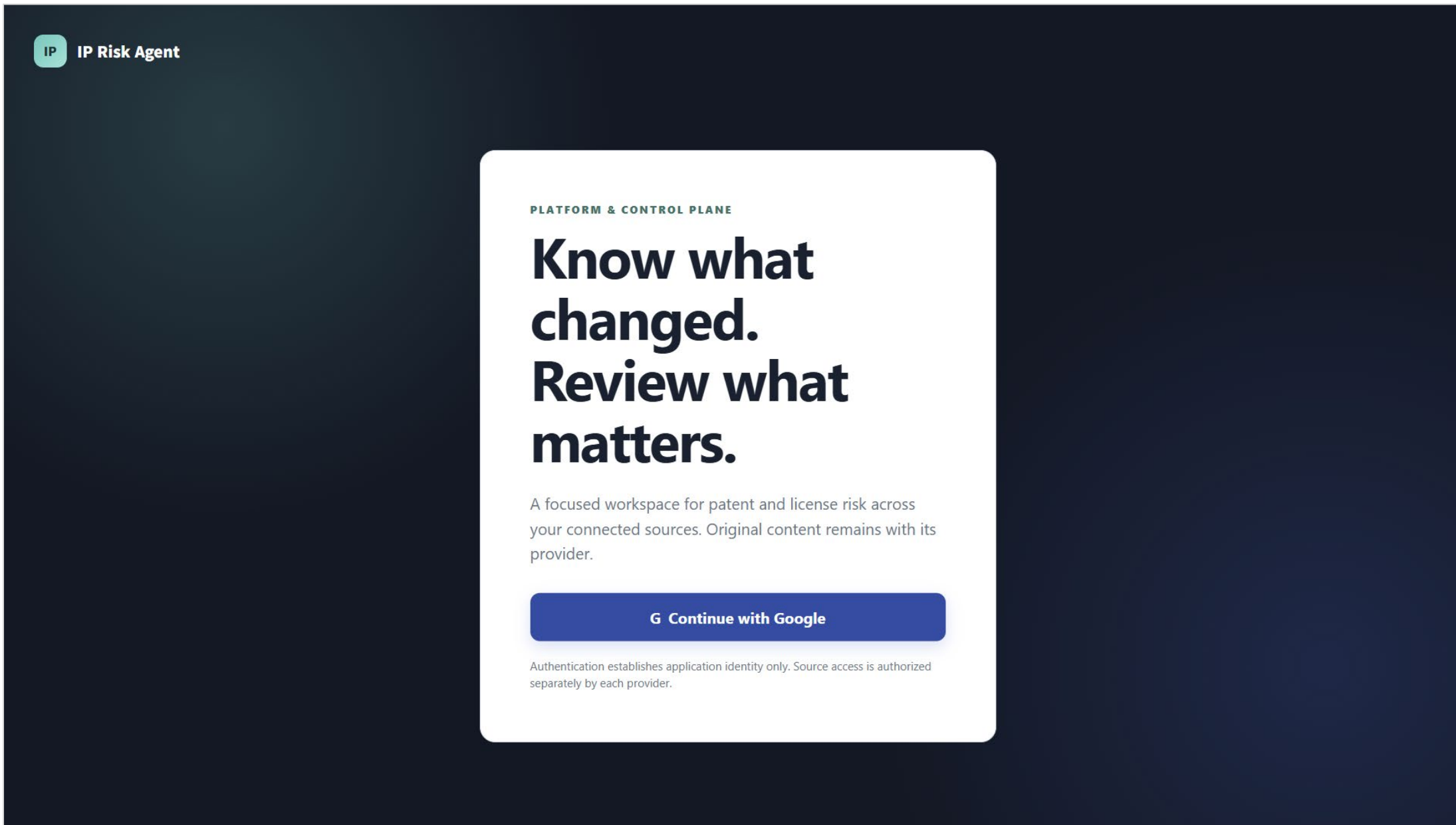
이후 페이지는 시연 영상을 대체합니다

실제 배포본에서 캡처한 16개 화면(SCR-00 ~ SCR-15)을 화면 흐름 순서대로 수록했습니다. 각 장은 목적 · 핵심 구성 · 권한을 함께 명시합니다.

부록 구성 APPENDIX MAP

SCR-00 로그인	SCR-01 Workspaces	SCR-02 Overview	SCR-03 Files 루트
SCR-04 Files 내부	SCR-05 Add Source	SCR-06 Review	SCR-07 Risk 요약
SCR-08 근거 대조	SCR-09 설명·권고	SCR-10 처분 모달	SCR-11 Timeline
SCR-12 Members	SCR-13 Activity	SCR-14 Notifications	SCR-15 Security

로그인 — Google OIDC 로그인



#/login (미인증 진입점)

목적

Google OIDC 로 애플리케이션 신원만 수립하고 로그인한다.

핵심 구성

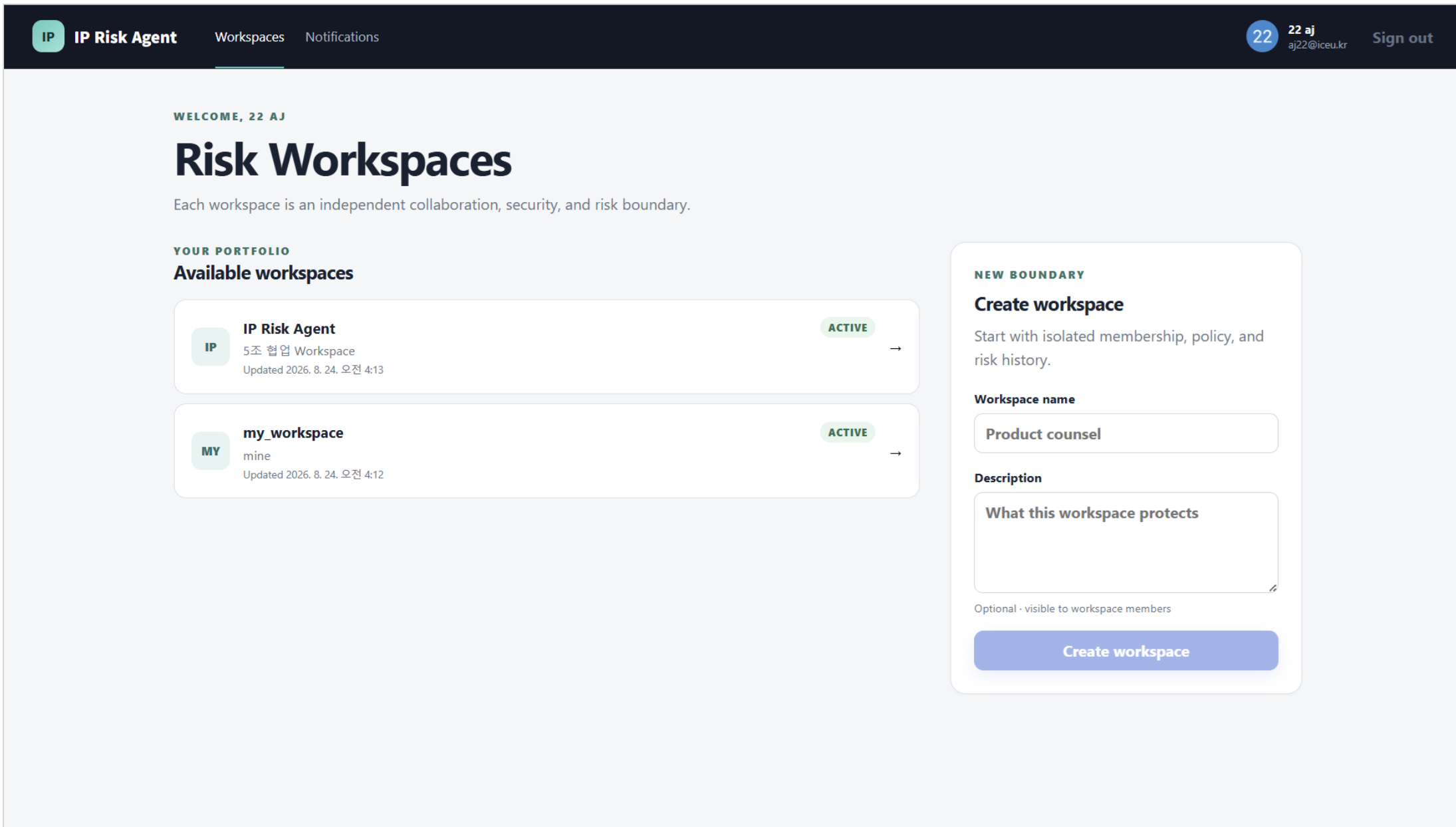
- Continue with Google 단일 버튼 — 자체 비밀번호 없음

권한

전원. 로그인만으로는 어떤 원문에도 접근할 수 없다.

로그인 ≠ 소스 접근 — provider 권한(폴더 공유 · App 설치 · 기기 등록)은 소스마다 별도로 성립한다.

Risk Workspaces — 워크스페이스 선택



#/ (로그인 후 진입점)

목적

협업·보안·리스크 이력이 격리되는 워크스페이스를 고르거나 만든다.

핵심 구성

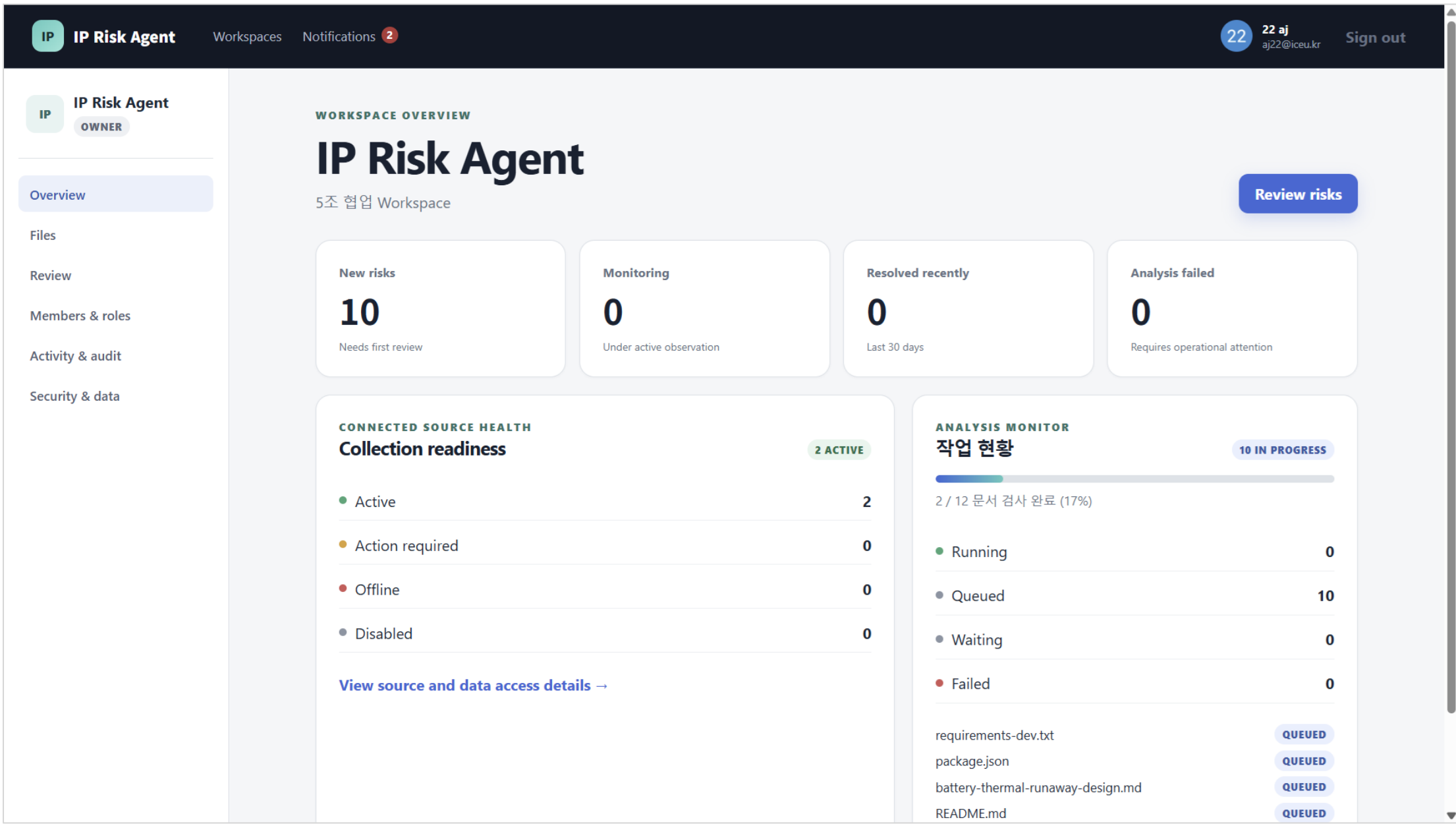
- Available workspaces — 상태 배지(ACTIVE)와 갱신 시각
- Create workspace — 이름·설명만으로 생성 (New boundary)

권한

로그인 사용자 누구나. 생성자는 자동으로 Owner.

헤더 공통 구성 — Workspaces · Notifications(뱃지) · 계정 · Sign out

Overview — 워크스페이스 현황



캡처 상태는 초기 스캔 중 — 진행 상태를 어떻게 표현하는지 보여주는 예시다.

#/w/{vws}/ (Overview 탭)

목적

리스크·소스·분석 작업의 현재 상태를 한 화면에서 파악한다.

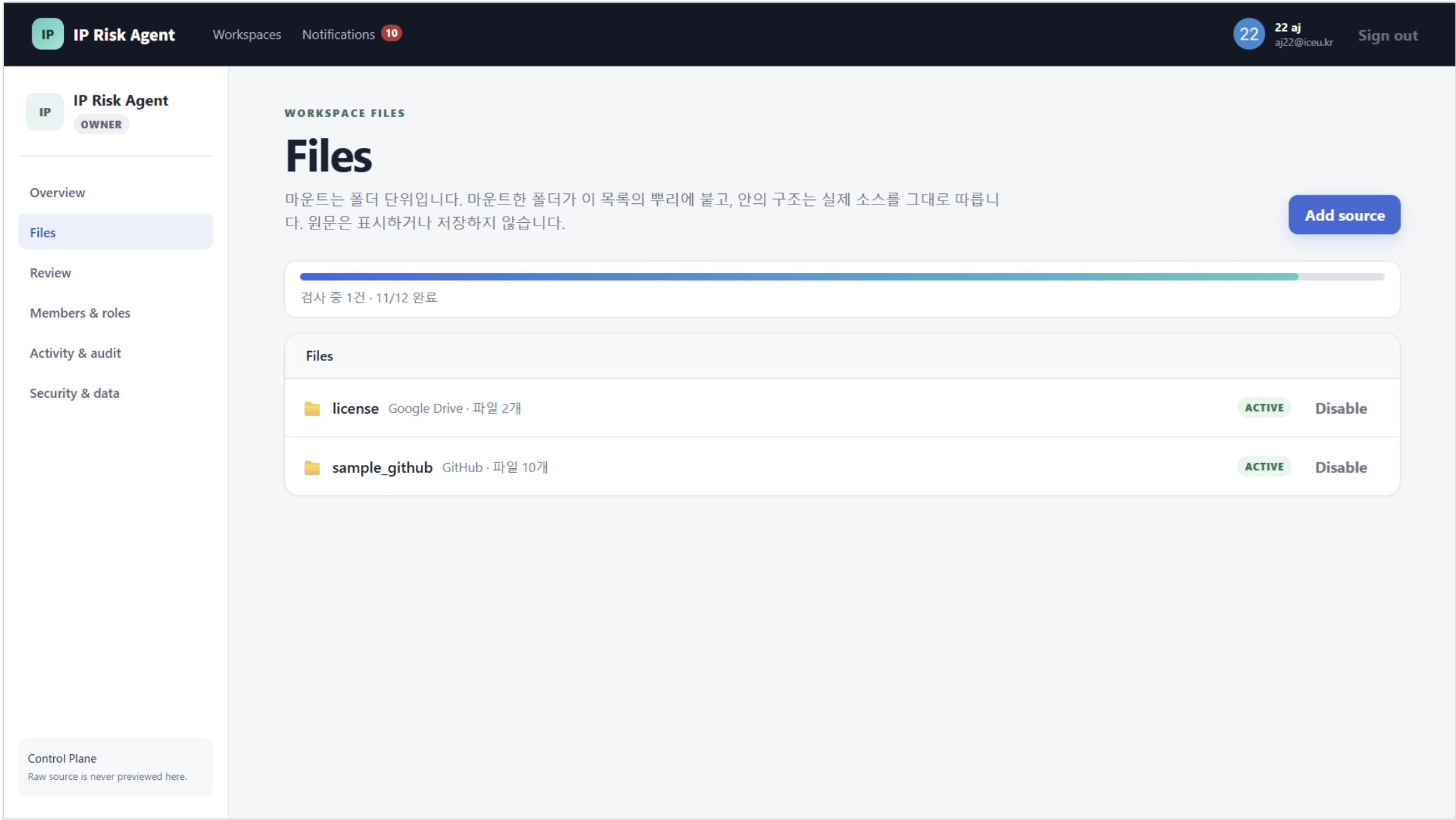
핵심 구성

- KPI 4 — New risks · Monitoring · Resolved(30d) · Analysis failed
- Collection readiness — 소스 상태(Active / Action required / Offline / Disabled)
- Analysis monitor — 진행률 · Running / Queued / Waiting / Failed + 파일별 큐 상태

권한

Viewer 이상 조회.

Files — 마운트 루트



원문은 이 화면에 표시하지도, 저장하지도 않는다 — 좌하단 Control Plane 문구가 고정으로 붙는다.

#/w/{vws}/files

목적

연결된 소스(마운트)를 폴더 트리의 뿌리로 보여준다.

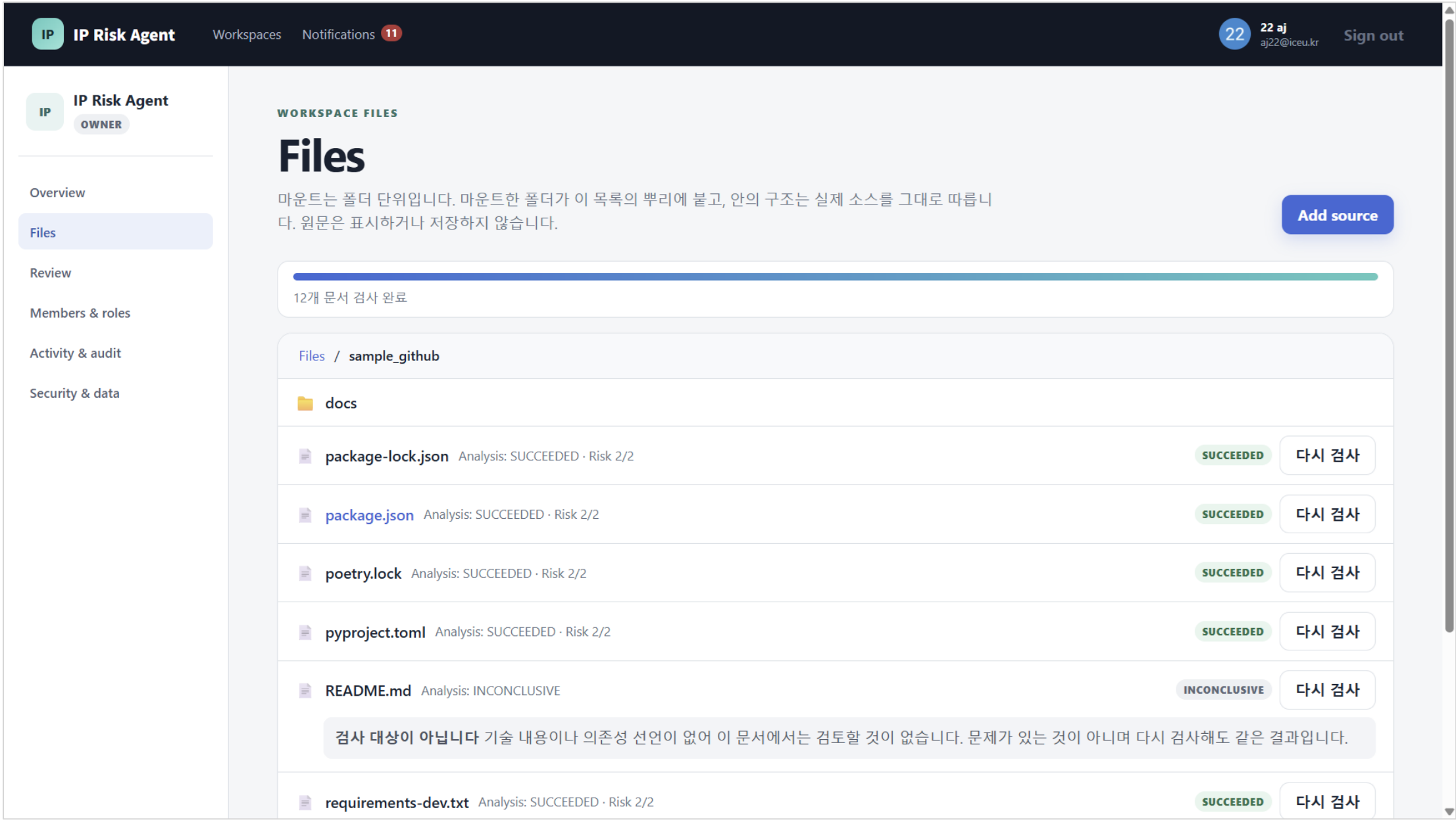
핵심 구성

- 폴더 단위 마운트 — 파일 하나씩이 아니라 폴더를 통째로 연결
- 검사 진행 바 — n건 검사 중 · m / 전체 완료
- 마운트 행 — 이름 · provider · 파일 수 · ACTIVE / Disable

권한

조회 Viewer+ · Add source / Disable 은 Source Manager+.

Files — 폴더 내부와 분석 상태



README.md 의 INCONCLUSIVE 배너가 이 화면의 핵심 상태 변형 — 실패와 비대상을 구분해 말한다.

#/w/{vws}/files/{path}

목적

파일별 분석 결과와 리스크 수를 확인하고 개별 조치를 한다.

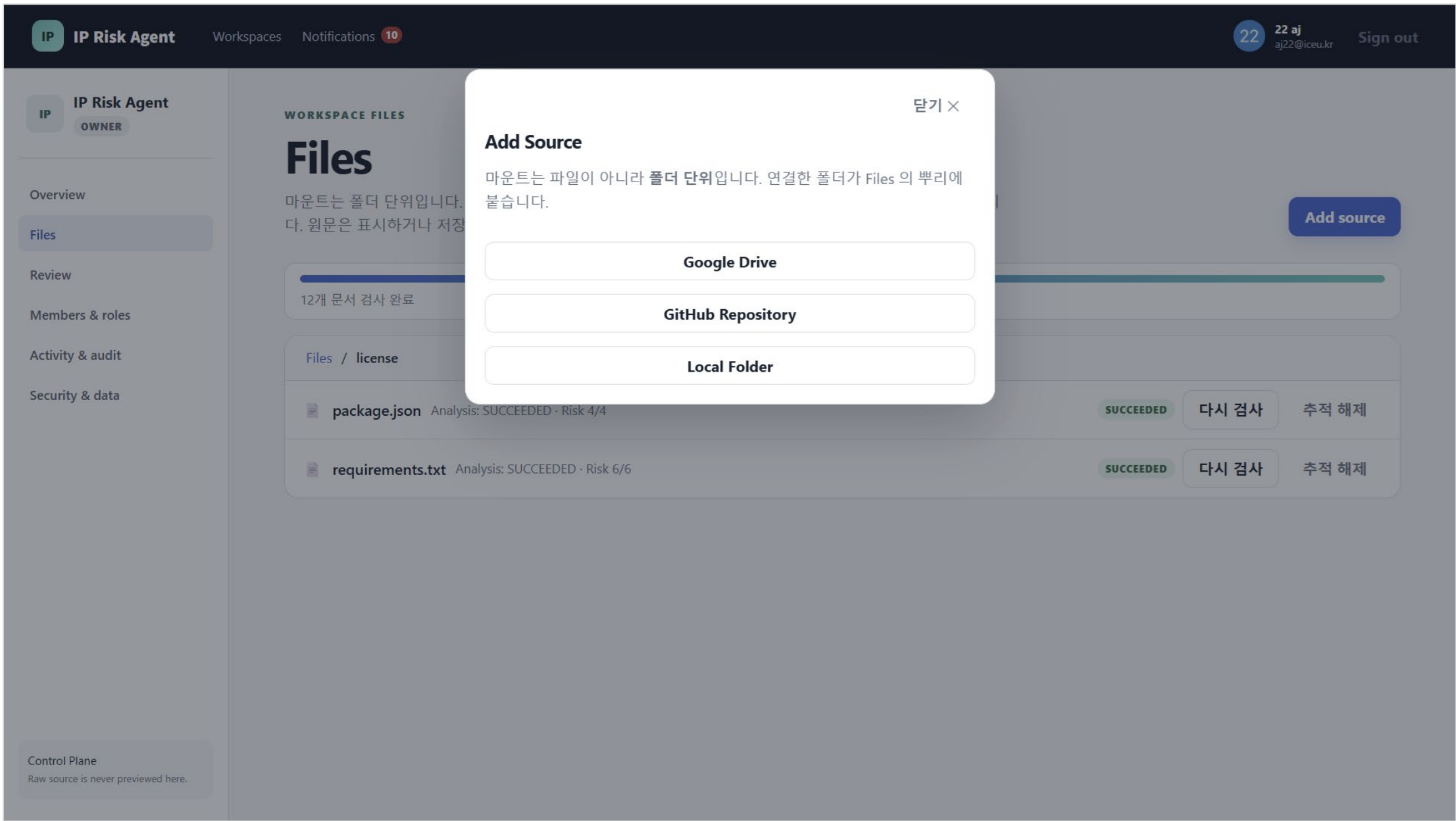
핵심 구성

- breadcrumb (Files / sample_github) · 하위 폴더 진입
- 파일 행 — Analysis 상태 · Risk n/n · 다시 검사
- INCONCLUSIVE 안내 배너 (README.md)

권한

조회 Viewer+ · 다시 검사 / 추적 해제는 Source Manager+.

Add Source 모달



Files → Add source

목적

세 provider 중 하나를 골라 폴더 단위 연결을 시작한다.

핵심 구성

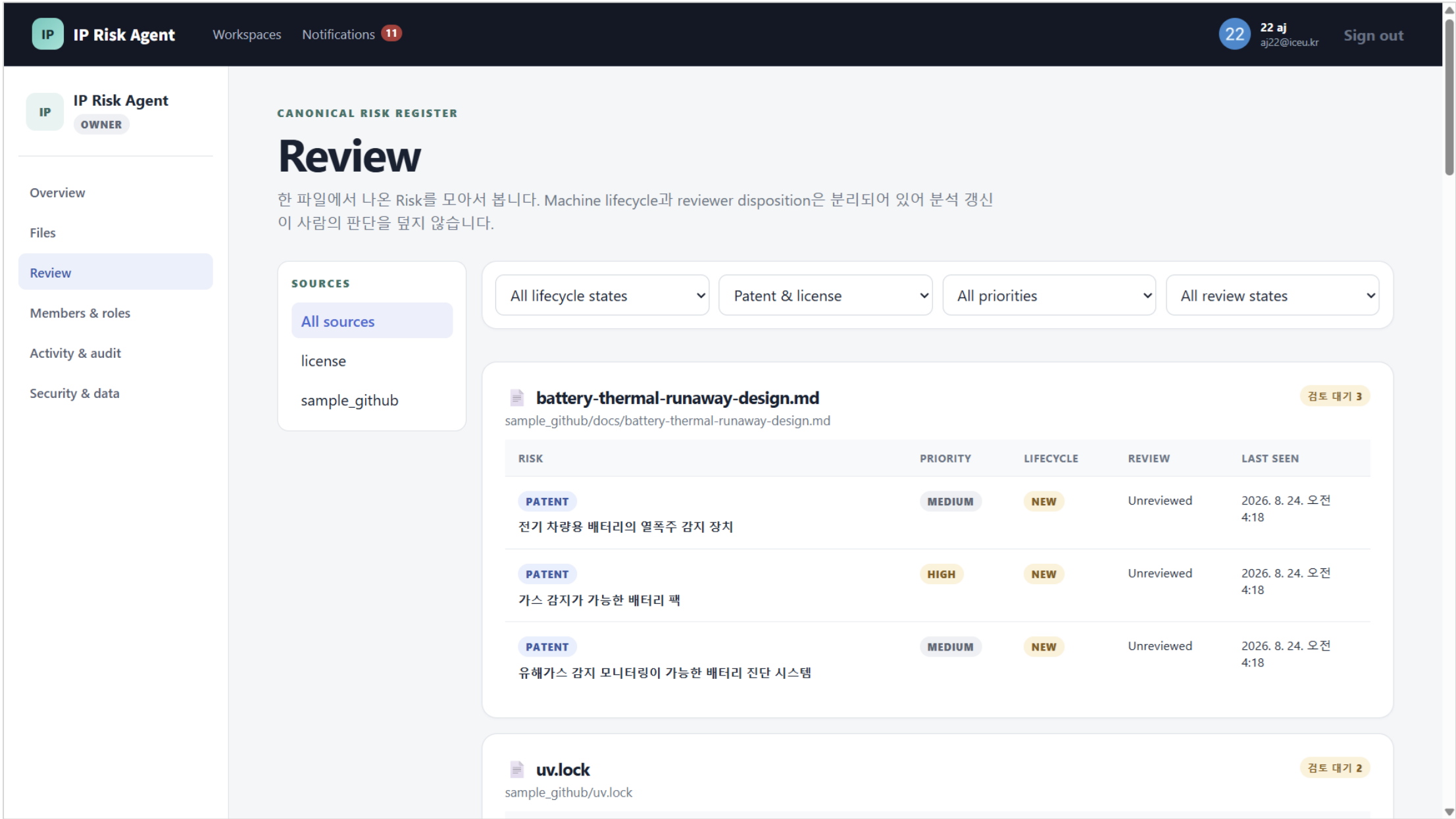
- Google Drive · GitHub Repository · Local Folder 세 진입
- 어느 provider 든 동일한 폴더 단위 마운트 규약을 따른다

권한

Source Manager 이상.

연결 범위를 사용자가 직접 고른다 — 고르지 않은 범위는 수집 대상이 되지 않는다.

Review — 파일 단위 Risk 묶음



PRIORITY 열이 4등급 체계(LOW · MEDIUM · INDETERMINATE · HIGH)가 드러나는 지점이다.

#/w/{vws}/review

목적

한 파일에서 나온 Risk 를 묶어 검토 대기 순으로 훑는다.

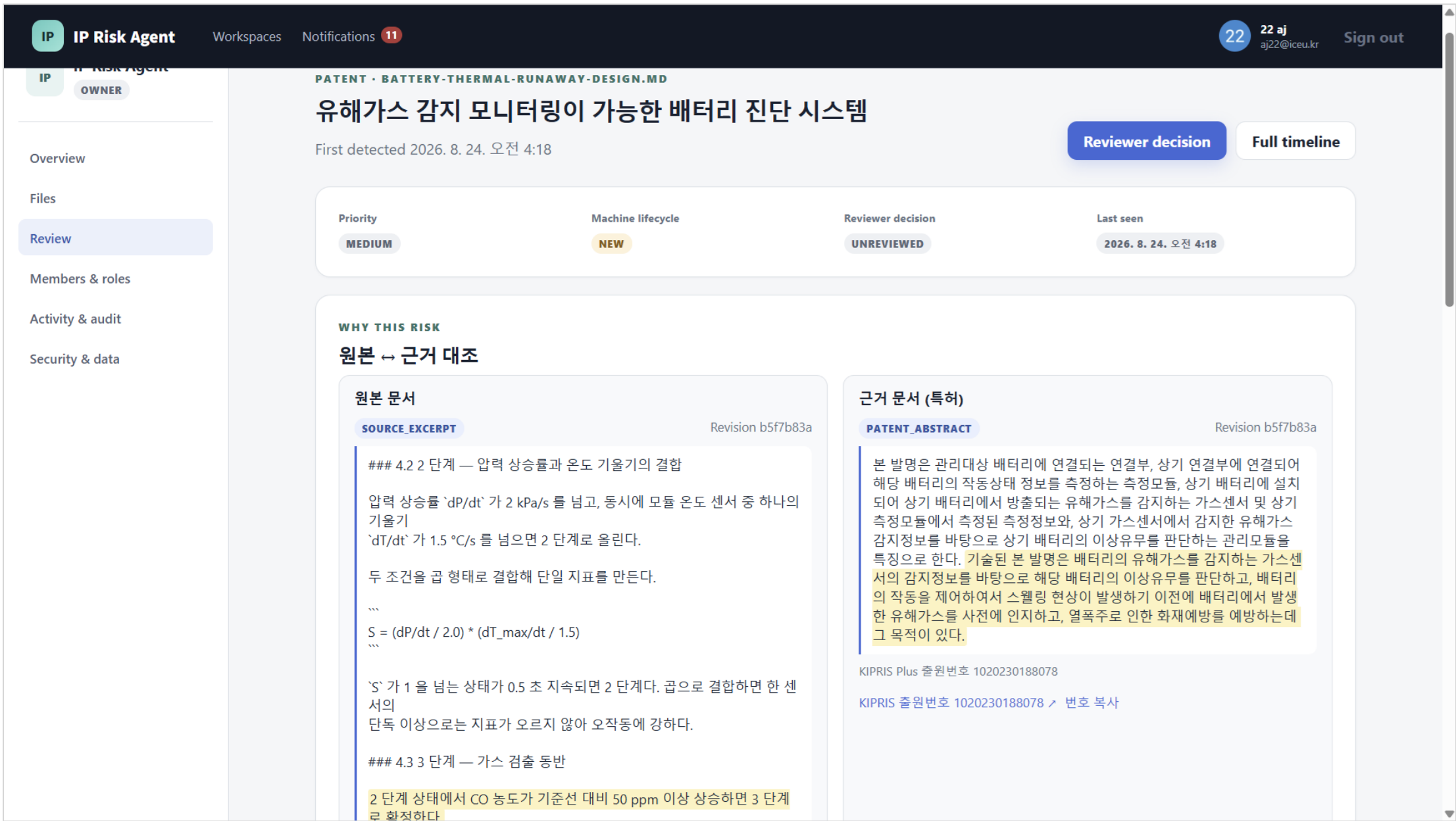
핵심 구성

- Sources 사이드 필터 + 상단 필터 4종 (lifecycle · 종류 · priority · review)
- 파일 카드 — 검토 대기 n 배지
- Risk 행 — 종류 · PRIORITY · LIFECYCLE · REVIEW · LAST SEEN

권한

조회 Viewer+ · 처분 입력은 Risk Reviewer+.

Risk 상세 — 요약과 판정



#/w/{vws}/risks/{id}

목적

리스크 한 건의 판정·우선순위·검토 상태를 한눈에 잡는다.

핵심 구성

- 상단 메타 — Priority · Machine lifecycle · Reviewer decision · Last seen
- Reviewer decision / Full timeline 진입 버튼
- First detected 시각 — 이후 모든 이력의 기준점

권한

조회 Viewer+ · decision 은 Risk Reviewer+.

기계가 매기는 lifecycle 과 사람이 남기는 decision 은 서로 다른 축 — 한 화면에 나란히 둔다.

Risk 상세 — 원본 ↔ 근거 대조

IP

IP Risk Agent

Workspaces

Notifications 9

22

22 aj
aj22@iceu.kr

Sign out

Activity & audit

Security & data

WHY THIS RISK

원본 ↔ 근거 대조

원본 문서

SOURCE_EXCERPT

Revision b5f7b83a

4.2 2 단계 — 압력 상승률과 온도 기울기의 결합

압력 상승률 `dP/dt` 가 2 kPa/s 를 넘고, 동시에 모듈 온도 센서 중 하나의 기울기 `dT/dt` 가 1.5 °C/s 를 넘으면 2 단계로 올린다.

두 조건을 곱 형태로 결합해 단일 지표를 만든다.

...

$$S = (dP/dt / 2.0) * (dT_max/dt / 1.5)$$

...

`S` 가 1 을 넘는 상태가 0.5 초 지속되면 2 단계다. 곱으로 결합하면 한 센서의 단독 이상으로는 지표가 오르지 않아 오작동에 강하다.

4.3 3 단계 — 가스 검출 동반

2 단계 상태에서 CO 농도가 기준선 대비 50 ppm 이상 상승하면 3 단계로 확정한다.

전해액 분해 가스가 실제로 방출된 상태이며, 열폭주가 시작된 것으로 본다.

5. 구동

| 단계 | 동작 |

|---|---

| 1 | 해당 모듈 충방전 전류를 정격의 20 % 로 제한, 로그 기록 시작 |

| 2 | 냉각 밸브를 열어 해당 모듈에 냉매를 우선 공급, 상위 제어기에 경고 전송 |

| 3 | 주 접속기 차단, 모듈 격리, 차량 경보 및 승객 하차 안내 |

sample.github/docs/battery-thermal-runaway-design.md

근거 문서 (특허)

PATENT_ABSTRACT

Revision b5f7b83a

본 발명은 관리대상 배터리에 연결되는 연결부, 상기 연결부에 연결되어 해당 배터리의 작동상태 정보를 측정하는 측정모듈, 상기 배터리에 설치되어 상기 배터리에서 방출되는 유해가스를 감지하는 가스센서 및 상기 측정모듈에서 측정된 측정정보와, 상기 가스센서에서 감지한 유해가스 감지정보를 바탕으로 상기 배터리의 이상유무를 판단하는 관리모듈을 특징으로 한다. 기술된 본 발명은 배터리의 유해가스를 감지하는 가스센서의 감지정보를 바탕으로 해당 배터리의 이상유무를 판단하고, 배터리의 작동을 제어하여서 스웰링 현상이 발생하기 이전에 배터리에서 발생한 유해가스를 사전에 인지하고, 열폭주로 인한 화재예방을 예방하는데 그 목적이 있다.

KIPRIS Plus 출원번호 1020230188078

KIPRIS 출원번호 1020230188078 > 번호 복사

동일 화면 · WHY THIS RISK

목적

이 리스크가 왜 났는지 원본 발체와 특허 근거를 나란히 검증한다.

핵심 구성

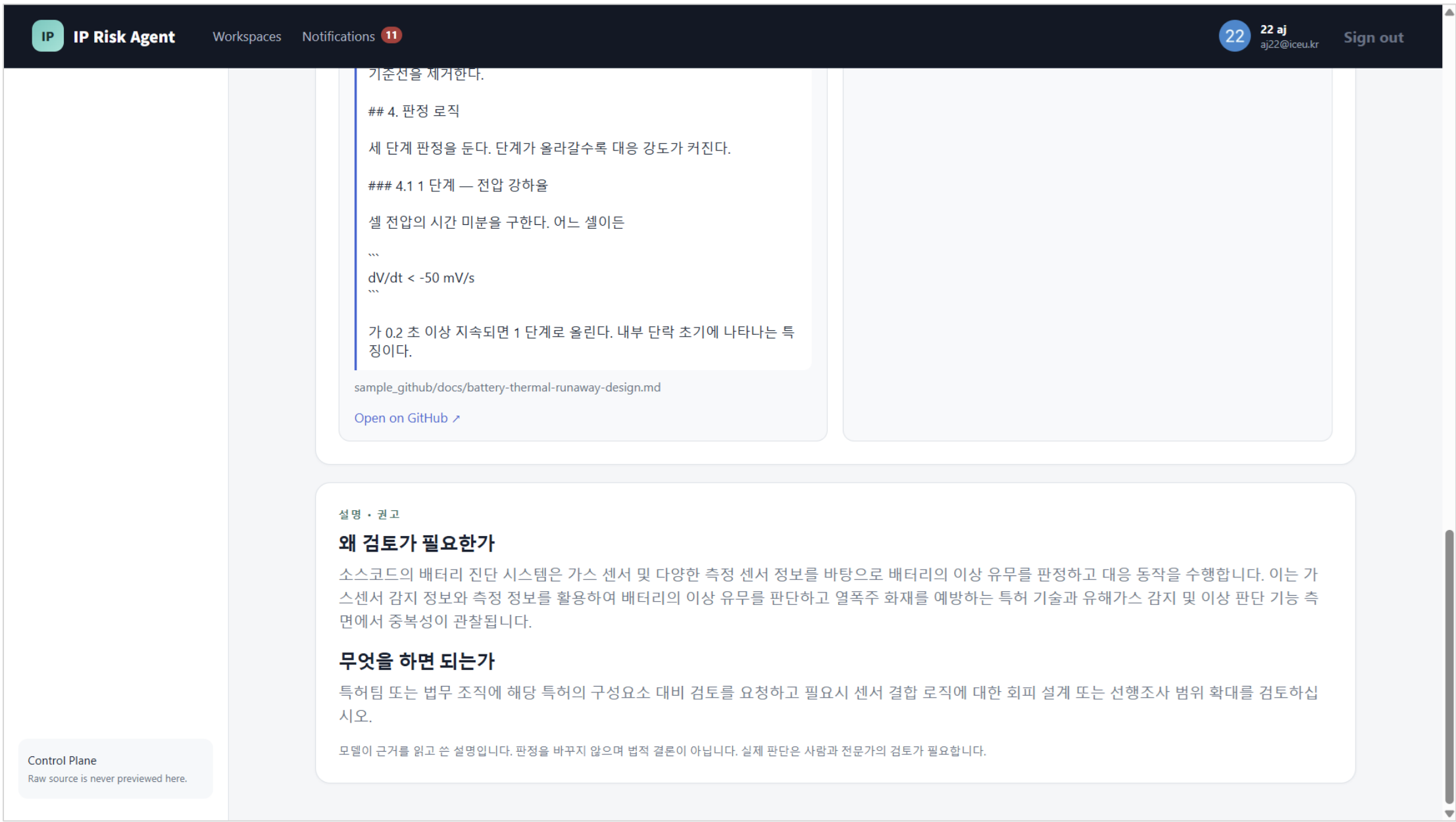
- 원본 문서(SOURCE_EXCERPT) vs 근거 문서 (PATENT_ABSTRACT) 2열
- 양쪽 겹침 구간 하이라이트 — 어떤 문장이 어떤 청구 요지와 겹치는가
- KIPRIS 출원번호 링크 · 번호 복사 · Revision 표기

권한

조회 Viewer+.

SOURCE_EXCERPT 는 분석 시점의 발체다 — 원문 전문 미리보기가 아니다.

Risk 상세 — 설명·권고와 AI 경계



동일 화면 하단

목적

검침의 이유와 다음 행동을 사람이 읽을 수 있는 말로 제공한다.

핵심 구성

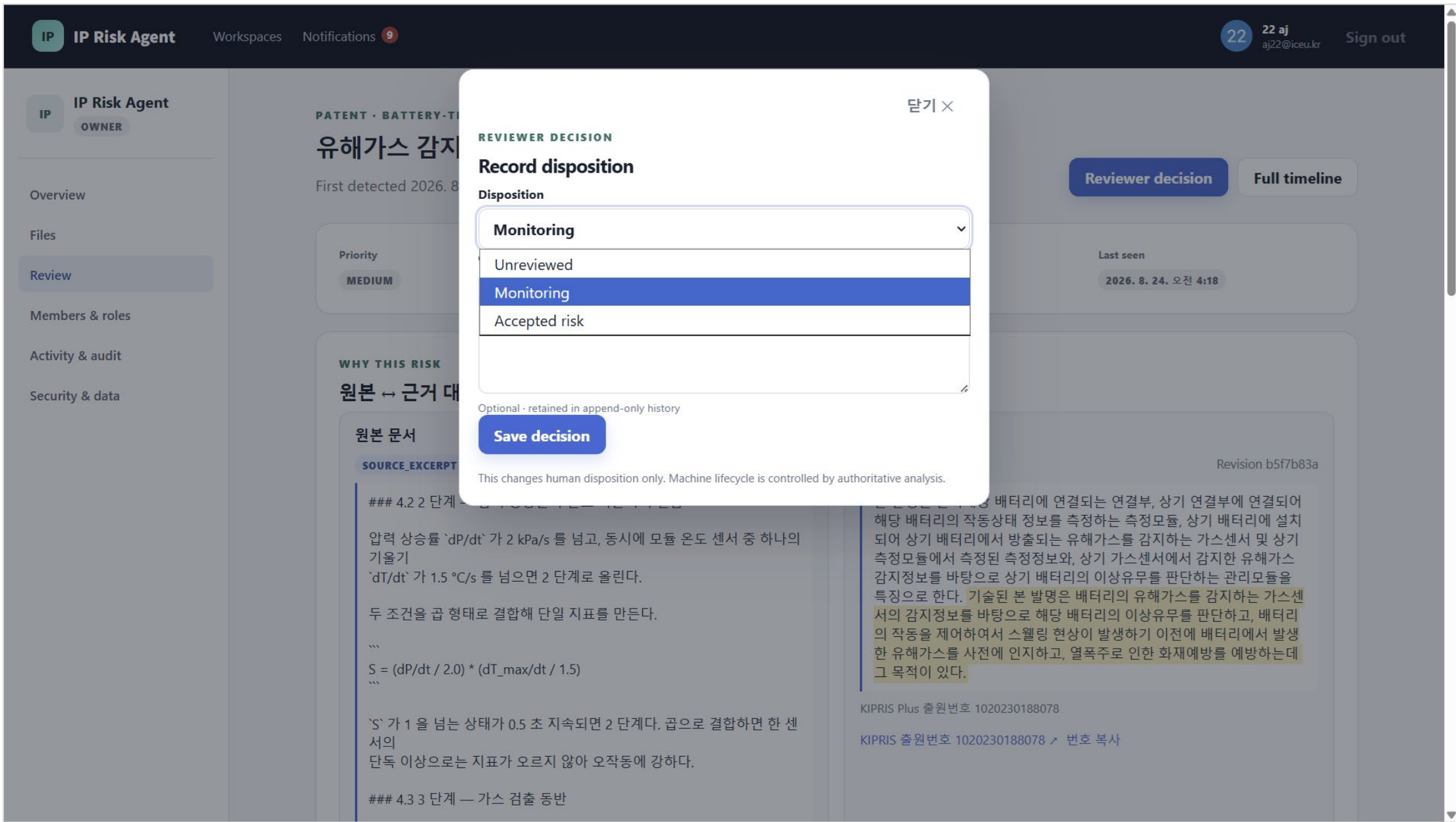
- 원본 발체 연속 + 소스 경로 · Open on GitHub 원문 링크
- "왜 검토가 필요한가" / "무엇을 하면 되는가" 2단 설명

권한

조회 Viewer+.

설명은 검증된 근거가 있을 때만 생성된다 — AI 는 판정이 아니라 설명을 맡는다.

Reviewer decision — 처분 입력 모달



Risk 상세 → Reviewer decision

목적

사람의 판단(disposition)을 사유와 함께 기록한다.

핵심 구성

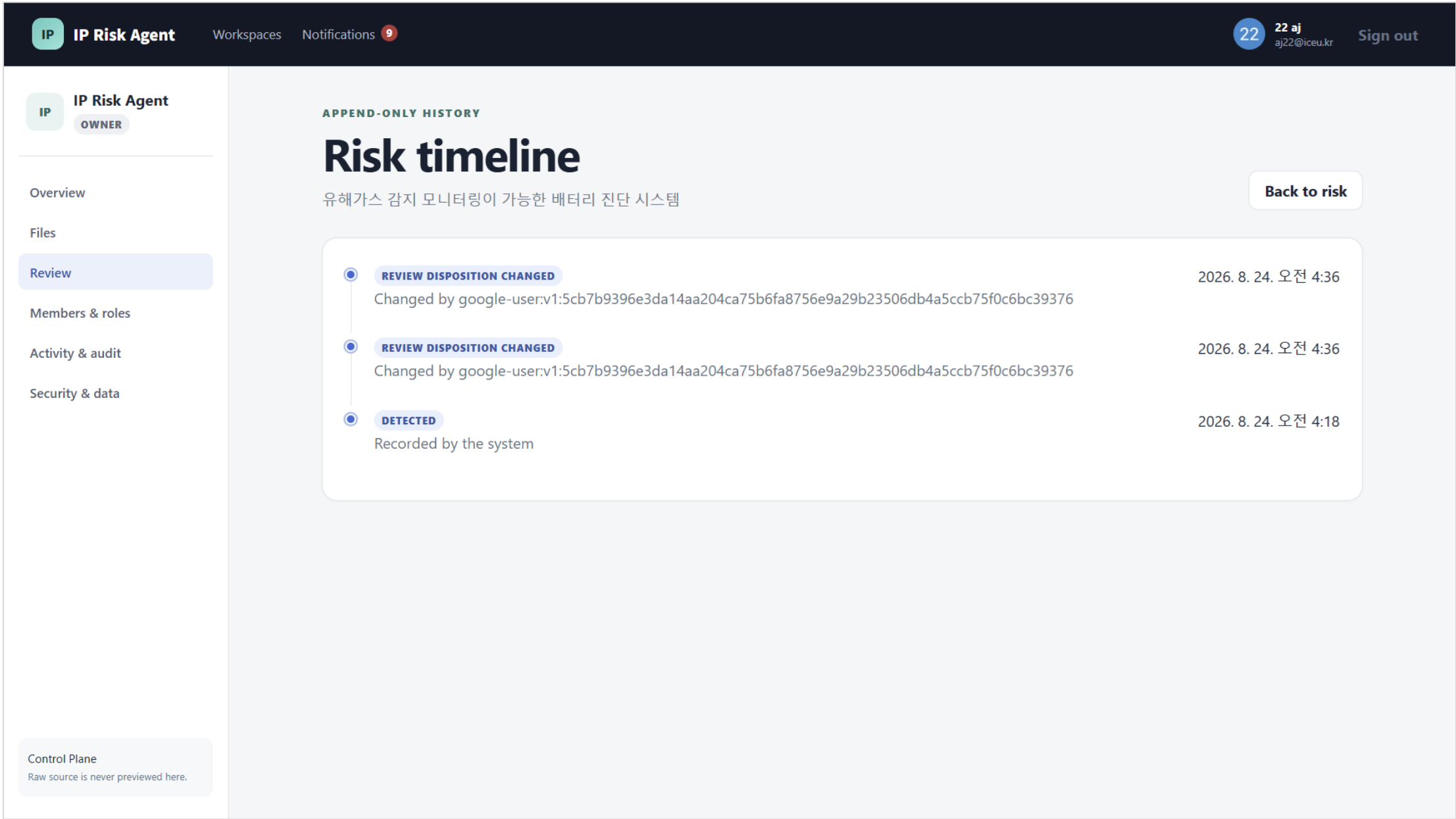
- Disposition 선택 — Unreviewed · Monitoring · Accepted risk
- 사유 입력란 — Optional · retained in append-only history
- Save decision

권한

Risk Reviewer 이상.

사유는 append-only 이력에 남는다 — 처분 변경도 삭제가 아니라 새 이력이다.

Risk timeline — append-only 이력



APPEND-ONLY HISTORY — 파일이 폴더를 이탈했다 돌아와도 이 이력 위에 복원된다.

Risk 상세 → Full timeline

목적

리스크 한 건에 쌓인 판단·검출 이력을 시간순으로 재구성한다.

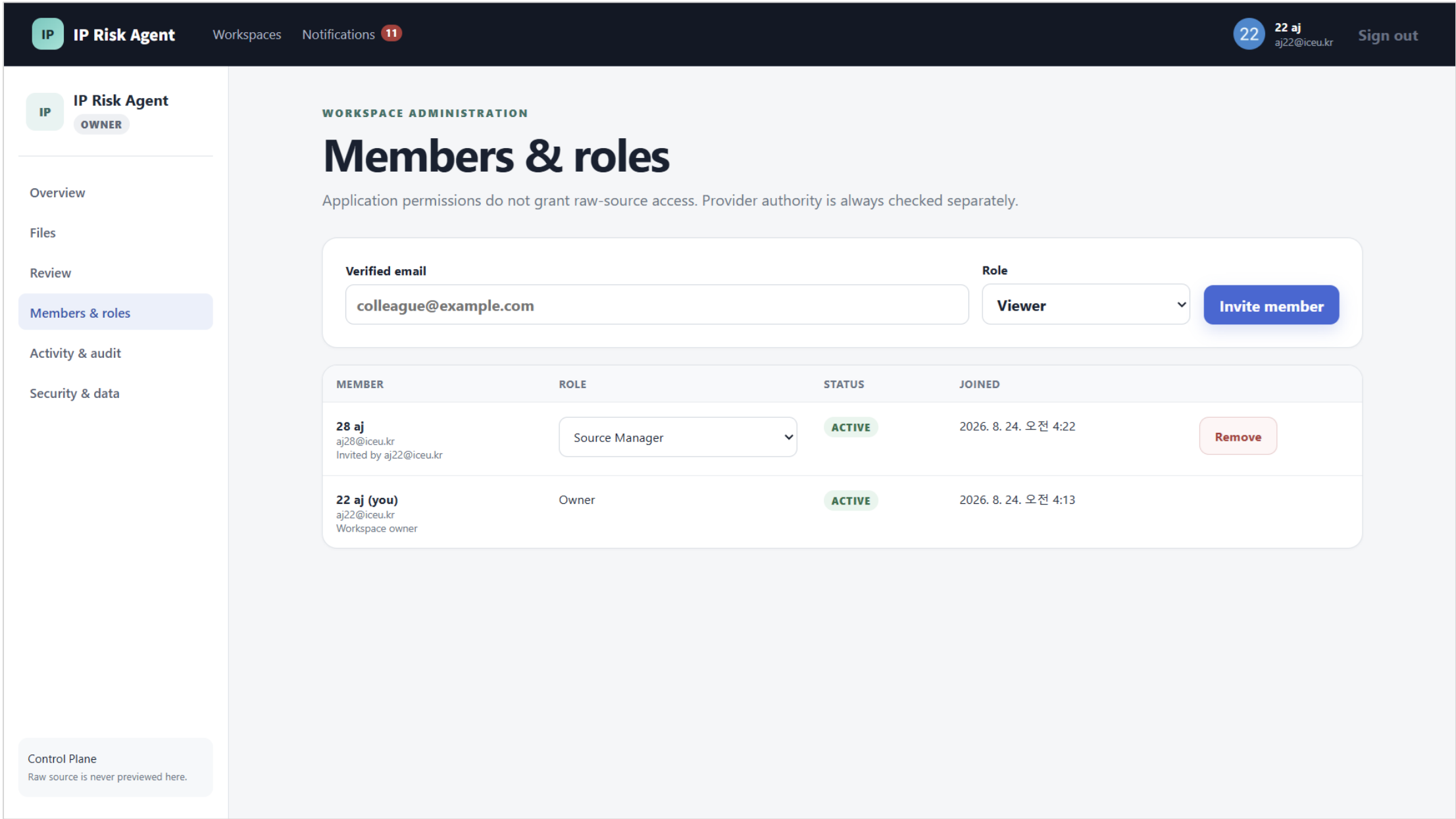
핵심 구성

- 이벤트 행 — REVIEW DISPOSITION CHANGED · DETECTED 배지 + 시각
- 행위자 표기 — 사람 처분은 사용자 식별자, 검출은 Recorded by the system
- Back to risk 복귀

권한

조회 Viewer+.

Members & roles



#/w/{vws}/members

목적

워크스페이스 멤버와 역할(RBAC)을 관리한다.

핵심 구성

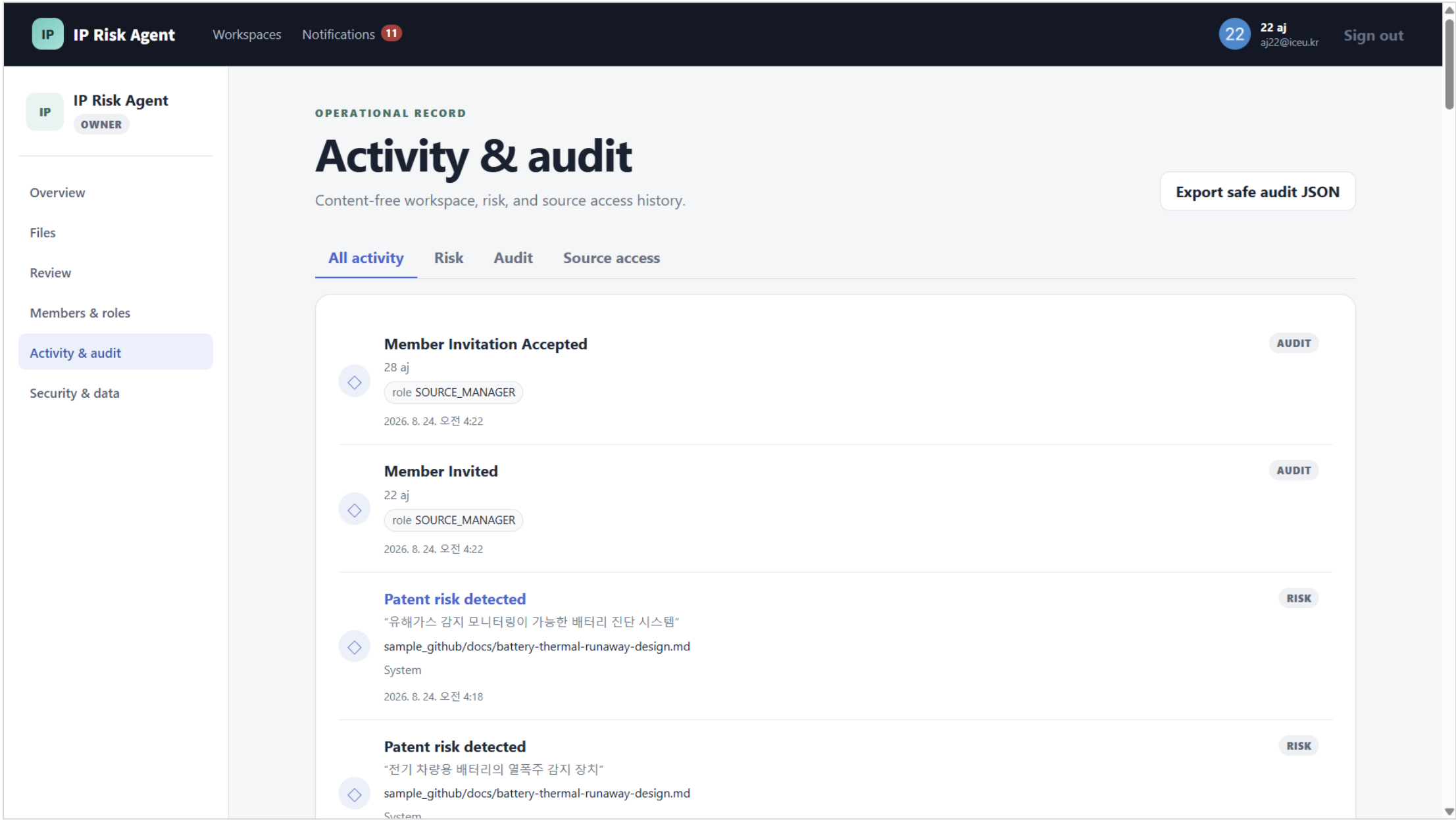
- 초대 — verified email + 역할 선택
- 역할 4종 — Viewer / Risk Reviewer / Source Manager / Owner
- 멤버 표 — 역할 드롭다운 · 상태 · 합류 시각 · Remove

권한

Owner 만 초대 · 역할 변경 · 제거.

여기서 정한 역할 4종이 이 제품의 권한 축이다 — 화면별 적용은 본문 PAGE 10 권한 매트릭스로 정리했다.

Activity & audit



이력은 전부 content-free — 무엇이 있었는지는 남기되 원문 내용은 남기지 않는다.

#/w/{vws}/history

목적

워크스페이스·리스크·원문 접근의 이력을 시간순으로 감사한다.

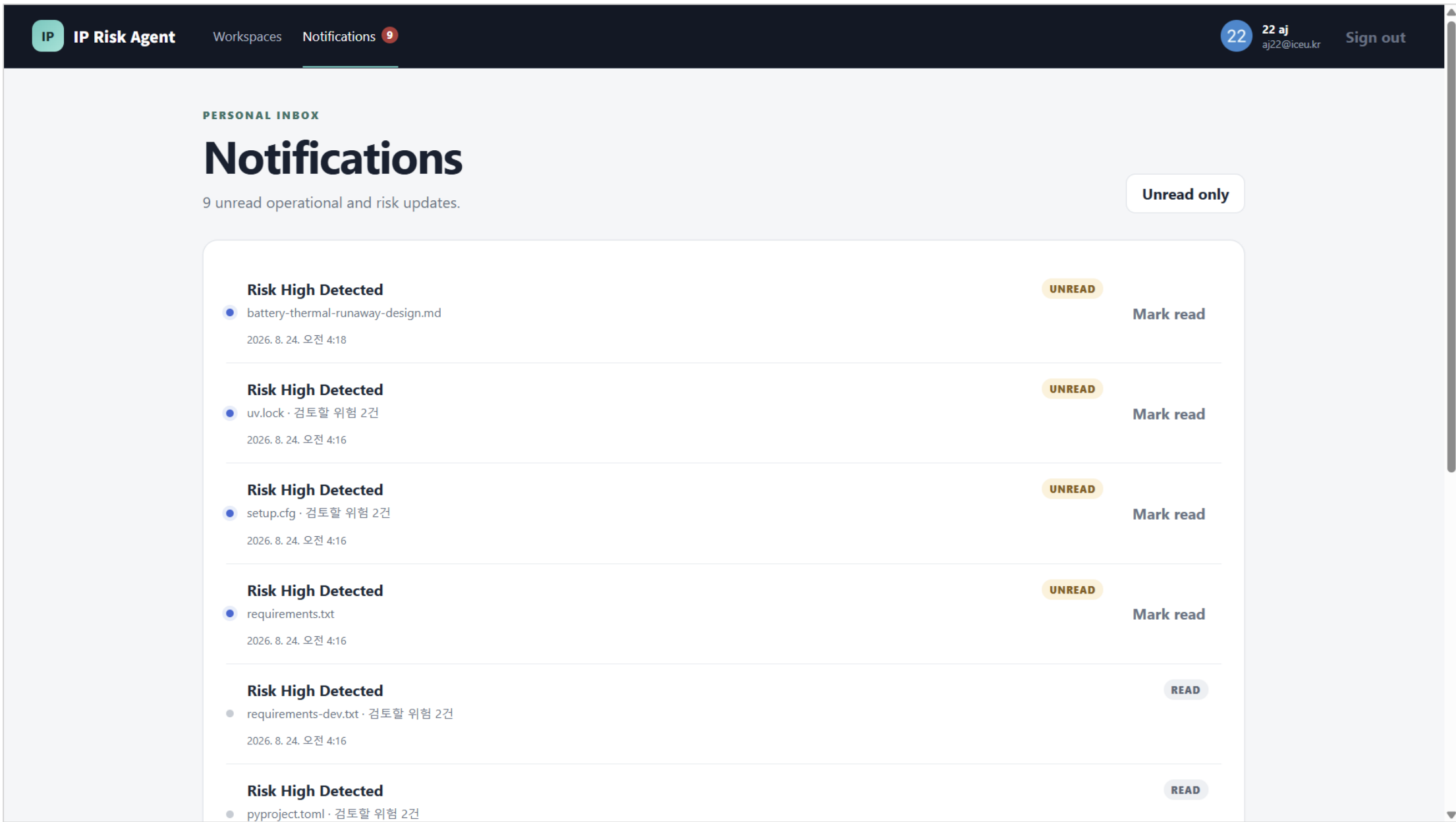
핵심 구성

- 탭 4 — All activity · Risk · Audit · Source access
- 이벤트 카드 — 종류 배지(AUDIT / RISK) · 행위자 · 시각
- Export safe audit JSON

권한

조회 Viewer+ · safe audit JSON 내보내기는 Owner.

Notifications — 개인 인박스



워크스페이스 경계 밖의 전역 인박스 — 알림 본문에도 원문 내용은 담기지 않는다.

#/notifications (전역)

목적

리스크 발생·운영 이벤트를 워크스페이스 밖에서 모아 본다.

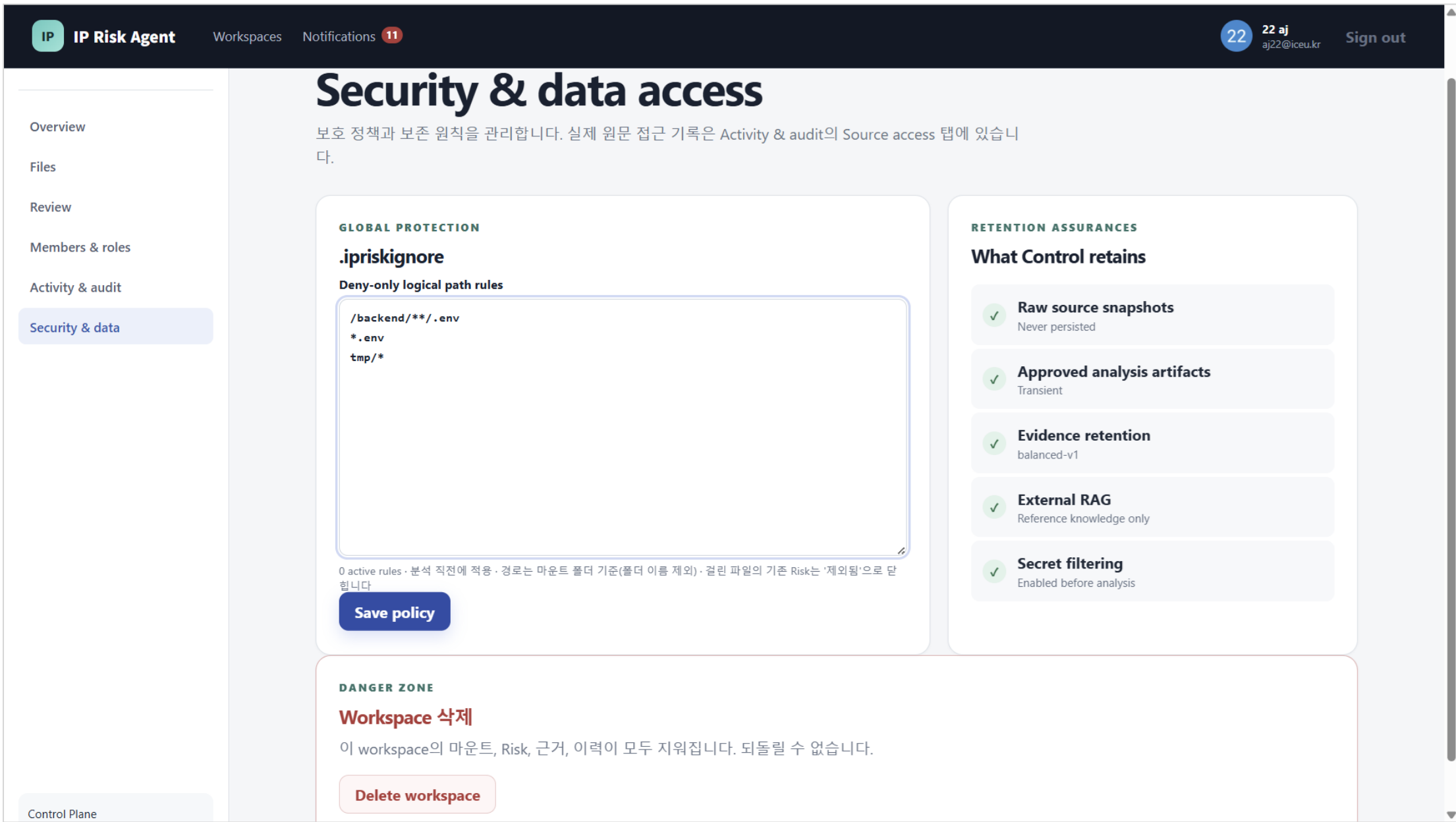
핵심 구성

- UNREAD / READ 상태 · Mark read · Unread only 필터
- Risk High Detected — 파일명 · 검토할 위험 n건 · 시각

권한

본인 것만.

Security & data access



#/w/{vws}/security

목적

분석 제외 정책과 데이터 보존 원칙을 관리한다.

핵심 구성

- .ipriskignore 편집기 — deny-only 규칙 + 적용 기준 안내 + Save policy
- Retention assurances 5 — Raw snapshots · artifacts · Evidence retention · External RAG · Secret filtering
- Danger zone — Workspace 삭제 (비가역 경고)

권한

Owner (VWS_SECURITY_MANAGE).

Raw snapshots 는 Never persisted — 보존 원칙을 문서가 아니라 화면에서 직접 명시한다.

공통 UI 규칙과 상태 어휘

화면이 달라도 같은 어휘와 같은 규칙을 사용합니다 — 사용자는 어느 화면에서든 같은 형태로 상태를 읽습니다

상태 어휘 STATE VOCABULARY

구분	상태 값
분석 상태	SUCCEEDED · INCONCLUSIVE · FAILED · QUEUED · RUNNING SUCCEEDED: 분석 완료, INCONCLUSIVE: 검사 비대상, FAILED: 사유 코드 동반, QUEUED / RUNNING: 대기 · 실행 중
수명주기 · 기계	NEW → EXISTING → RESOLVED NEW: 새로이 나온 사항, EXISTING: 기존에 있던 사항, RESOLVED: 기존에 있었으나 해결된 사항
검토 처분 · 사람	UNREVIEWED · MONITORING · ACCEPTED RISK UNREVIEWED: 아직 의견이 기재되지 않음, MONITORING: 사용자 지속 추적 허용, ACCEPTED: 위험 수용
우선순위	LOW · MEDIUM · INDETERMINATE · HIGH
소스 상태	ACTIVE · ACTION REQUIRED · DISABLED · OFFLINE ACTIVE: 현재 연결됨, REQUIRED: 외부요인으로 인해 조치 필요, DISABLED: mount 해제, OFFLINE: 서비스 장애

뱃지 색과 자간은 실제 배포본 UI 토큰을 그대로 사용했습니다

모든 화면의 불변 규칙 INVARIANTS

- 1

좌하단 고정 문구

Control Plane: Raw source is never previewed here.
- 2

실패 · 비대상 · 성공

세 결과를 절대 뭉뚱그리지 않고 항상 구분해 말한다.
- 3

이력 · 알림 · 감사

전부 content-free — 사건은 남기되 원문 내용은 남기지 않는다.
- 4

처분 모달

human disposition 과 machine lifecycle 의 분리를 화면에 명문화한다.

원문은 어느 화면에서도 미리보기되지 않습니다 — 화면은 판단에 필요한 발체와 근거만 보여주고, 최종 판단은 사람이 합니다.